

CISM CERTIFICATION EXAM SIMULATOR

Practice Exam 26

Domain II - Information Security Risk Management

30 Questions	48 Minutes	Single Best Answer Format
-----------------	---------------	------------------------------

This publication contains original practice material designed for exam preparation. It does not reproduce confidential certification questions and is not affiliated with or endorsed by ISACA.

Instructions

- Allow approximately 48 minutes for this domain set.
- Select one best answer for every question.
- Record your selections before consulting the answer key.
- Review every explanation, including questions you answered correctly.

Questions

Question 1 (CISM7-028)

Which statement BEST defines risk capacity?

- A. The exposure remaining after controls
- B. The risk selected for future treatment
- C. The maximum exposure the organization can absorb while remaining viable
- D. A specific variation permitted around an objective

Question 2 (CISM7-029)

Which information is MOST important when establishing risk context?

- A. Only vulnerability scan results
- B. Business objectives, obligations, dependencies, market, and threats
- C. Only prior incidents
- D. Only the security budget

Question 3 (CISM7-030)

Scenario: A digital lender wants to guarantee partner losses from a new product. The plausible aggregate loss exceeds available capital, although executives have a high appetite for growth.

Which conclusion is MOST appropriate?

- A. High appetite makes the exposure acceptable
- B. The assessment should use expected profit instead of loss
- C. Security should increase the capital estimate
- D. The exposure exceeds capacity and requires limitation, redesign, or another viable response

Question 4 (CISM7-031)

Scenario: An airport rates a baggage-reconciliation database as medium because it contains no payment data. If unavailable, bags cannot be matched to boarded passengers and flights may be delayed.

What should drive the impact rating?

- A. Database license cost
- B. The absence of payment data
- C. The number of database tables
- D. Safety, operational, and passenger-service consequences of unavailable reconciliation

Question 5 (CISM7-032)

Scenario: A subscription company contracts with two payment processors for resilience. Both route transactions through the same acquiring gateway and identity service.

Which risk should be added to the assessment?

- A. Every payment event will be duplicated
- B. Two contracts eliminate operational risk
- C. A shared dependency could cause simultaneous payment failure
- D. Processor pricing becomes an information security impact

Question 6 (CISM7-033)

Scenario: A mining company automatically installs signed equipment firmware. The signing key is held by one supplier, key protection has not been assessed, and rollback is impossible during production.

Which scenario is MOST material?

- A. Operators dislike the update interface
- B. Firmware has no separate license cost
- C. Compromise of the supplier signing process distributes trusted malicious firmware with difficult recovery
- D. The supplier uses a different project method

Question 7 (CISM7-034)

When is a semi-quantitative approach MOST useful?

- A. When management requires a guaranteed loss value
- B. When technical scores can be treated as currency
- C. When business impact is unknown and unnecessary
- D. When defined ranges can improve comparison despite limited precise loss data

Question 8 (CISM7-035)

Scenario: A pharmaceutical research service is valued at \$2,000,000. A modeled event would affect 10% of that value and occur 0.3 times per year.

What is the annualized loss expectancy?

- A. \$20,000
- B. \$200,000
- C. \$60,000
- D. \$600,000

Question 9 (CISM7-036)

Scenario: A hotel chain rated destructive-malware risk low last year. Current intelligence shows sustained targeting of identical property systems, while controls and potential impact are unchanged.

What should be updated?

- A. Increase impact automatically
- B. Reevaluate likelihood using the new targeting evidence
- C. Reduce inherent risk because controls are stable
- D. Wait until the chain is attacked

Question 10 (CISM7-037)

Scenario: A company requires monthly termination reviews. The control includes all worker types, but evidence shows three reviews were skipped after responsibility changed.

How should this be characterized?

- A. A design deficiency
- B. An impact
- C. An operating deficiency increasing unauthorized-access likelihood
- D. Proof of a breach

Question 11 (CISM7-038)

Scenario: A wholesaler records low residual risk because a new access-control platform is contracted for delivery in six months. Current exposure remains above tolerance.

How should the record be corrected?

- A. Report current residual risk and record the target state separately
- B. Remove the risk until delivery
- C. Reduce inherent risk
- D. Count the contract as an operating control

Question 12 (CISM7-039)

Scenario: Two scenarios have equal scores. One exposes resettable employee passwords; the other exposes biometric templates for millions of customers that cannot be reissued and triggers contractual duties.

Which should receive priority?

- A. Biometric exposure because scale, irreversibility, and obligations increase consequence
- B. Passwords because credentials are always first
- C. Neither because scores match
- D. Whichever has more vulnerabilities

Question 13 (CISM7-040)

Scenario: A financial model based on sparse events produces a wide outcome range, but an executive requests one exact loss value.

What should the information security manager provide?

- A. The maximum value as expected loss
- B. A range or distribution with assumptions, confidence, and sensitivity
- C. A technical severity score
- D. No estimate

Question 14 (CISM7-041)

Scenario: Four divisions rate reliance on a central time service as low. A single failure would invalidate transactions across all divisions and exceed enterprise appetite.

What is the MOST appropriate action?

- A. Report aggregate concentration while preserving local entries
- B. Delete local records
- C. Ignore enterprise appetite
- D. Average the low scores

Question 15 (CISM7-042)

Scenario: A port authority must decide whether to fund resilience for cargo scheduling. The assessment contains technical findings but no operational-impact scenarios or option comparison.

What should be presented FIRST?

- A. All scanner output
- B. Material scenarios, appetite, assumptions, and treatments
- C. Assessment labor hours
- D. A request to purchase every control

Question 16 (CISM7-043)

Which action BEST represents risk acceptance?

- A. Formally retaining residual exposure within authorized limits
- B. Discontinuing an activity
- C. Purchasing insurance
- D. Implementing a preventive control

Question 17 (CISM7-044)

Which allocation is MOST appropriate?

- A. Security accepts all risk
- B. The risk owner accepts risk; control owners operate controls
- C. Internal audit owns residual risk
- D. A supplier owns all outsourced risk

Question 18 (CISM7-045)

Scenario: Two controls reduce subscription-fraud risk within tolerance. One costs twice as much and adds customer delay; the other meets obligations without meaningful delay.

Which should be recommended?

- A. The lower-impact control achieving acceptable risk
- B. Both controls
- C. The costlier control
- D. Neither because risk remains

Question 19 (CISM7-046)

Scenario: A data service cannot meet a binding contractual security requirement. The owner proposes accepting the risk to meet a launch date, but policy does not allow waiver.

What is the BEST response?

- A. Record acceptance
- B. Buy insurance
- C. Comply or delay launch
- D. Launch and review later

Question 20 (CISM7-047)

Scenario: A retailer buys coverage for breach-notification costs. Outages, reputation, exclusions, and customer obligations remain with the retailer.

How should the response be recorded?

- A. Partial transfer retaining operational accountability
- B. Complete avoidance
- C. Elimination of impact
- D. Transfer of accountability to the insurer

Question 21 (CISM7-048)

Scenario: A hospital discovers after signature that a scheduling vendor subcontracts support to an unreviewed region. Security review begins only during deployment.

Which process change is MOST effective?

- A. Require risk-tiered data and subcontractor review
- B. Ban every subcontractor
- C. Review after deployment
- D. Let procurement accept all risk

Question 22 (CISM7-049)

Which measure is the BEST key risk indicator for credential-stuffing exposure?

- A. Awareness courses assigned
- B. Rate of high-confidence automated login attacks
- C. Policies reviewed
- D. Security hours worked

Question 23 (CISM7-050)

Scenario: An internal analytics service was accepted with no external access and daily reconciliation. A change adds partner access and weekly sampling.

What should occur before approval?

- A. Keep the old acceptance
- B. Approve because the service is unchanged
- C. Ask partners to accept risk
- D. Reassess because exposure and a key control assumption changed

Question 24 (CISM7-051)

Scenario: A transit operator cannot patch a certified controller. Proposed segmentation is tested, but a maintenance radio creates an undocumented path to the controller.

What should the information security manager do FIRST?

- A. Reassess before exception approval
- B. Accept for operations
- C. Ignore the radio
- D. Approve because segmentation exists

Question 25 (CISM7-052)

Scenario: A 90-day logging exception has been renewed four times. The compensating review has never been tested, and the original approver left.

What is the BEST action?

- A. Renew automatically
- B. Close the exception
- C. Make it permanent
- D. Reassess exposure and controls

Question 26 (CISM7-053)

Scenario: A temporary acceptance requires fraudulent transfers to remain below a set rate. The rate exceeds its trigger for three periods, although annual losses remain within budget.

What should happen NEXT?

- A. Wait for budget overrun
- B. Raise the trigger
- C. Invoke reassessment and a revised owner decision
- D. Close the risk

Question 27 (CISM7-054)

Scenario: A public-benefits portal has an above-tolerance privacy risk, but treatment has no owner, funding, or launch criterion.

What is the BEST corrective action?

- A. Move it to a postlaunch backlog
- B. Lower the rating
- C. Ask developers to accept it
- D. Fund treatment and require acceptable residual-risk evidence at launch

Question 28 (CISM7-055)

Scenario: Seven departments hold valid local exceptions to device encryption. Together they cover most executive laptops and exceed enterprise appetite.

What should be recommended?

- A. Keep only local reporting
- B. Report aggregate exposure while retaining local records
- C. Delete all exceptions
- D. Divide devices into smaller groups

Question 29 (CISM7-056)

Scenario: An acquired warehouse system is unsupported but essential for five months. Isolation and monitoring reduce risk to a temporarily approved tolerance while migration proceeds.

Which response is BEST?

- A. Accept indefinitely
- B. Use time-bound controls, documented acceptance, monitoring triggers, and a migration deadline
- C. Shut down regardless of impact
- D. Rely on the seller's past operation

Question 30 (CISM7-057)

Scenario: Executives receive overdue-task counts but cannot see whether cloud concentration risk is improving or what funding decision is needed.

Which reporting approach is MOST appropriate?

- A. Add every technical task
- B. Wait until treatment completes
- C. Report only spending
- D. Material risk, treatment, exceptions, and decisions

Answer Key

Domain II - Information Security Risk Management

1 C	2 B	3 D	4 D	5 C
6 C	7 D	8 C	9 B	10 C
11 A	12 A	13 B	14 A	15 B
16 A	17 B	18 A	19 C	20 A
21 A	22 B	23 D	24 A	25 D
26 C	27 D	28 B	29 B	30 D

Detailed Explanations

Question 1 (CISM7-028)

Correct answer: C - The maximum exposure the organization can absorb while remaining viable

Risk capacity is the maximum exposure the organization can absorb without threatening viability. Residual risk remains after controls, treatment selection is a response decision, and permitted variation describes tolerance.

Question 2 (CISM7-029)

Correct answer: B - Business objectives, obligations, dependencies, market, and threats

Risk context must combine internal objectives and capabilities with external obligations, dependencies, and threats. Scans, incidents, and budgets are useful inputs but are each too narrow on their own.

Question 3 (CISM7-030)

Correct answer: D - The exposure exceeds capacity and requires limitation, redesign, or another viable response

Appetite cannot make exposure beyond practical capacity sustainable. The organization must limit, redesign, or otherwise treat it; profit and estimate changes do not create loss-absorbing capacity.

Question 4 (CISM7-031)

Correct answer: D - Safety, operational, and passenger-service consequences of unavailable reconciliation

Impact follows business consequences, including flight operations and baggage safety. Cost, table count, and low payment-data sensitivity do not capture the availability dependency.

Question 5 (CISM7-032)

Correct answer: C - A shared dependency could cause simultaneous payment failure

The common gateway and identity service create concentration risk despite separate contracts. Redundancy is not real when dependencies are shared, duplication is not inevitable, and pricing is not the stated security exposure.

Question 6 (CISM7-033)

Correct answer: C - Compromise of the supplier signing process distributes trusted malicious firmware with difficult recovery

A compromised signing process could distribute malicious trusted updates at scale, while lack of rollback increases impact. Interface preference, price, and project method are not the core risk scenario.

Question 7 (CISM7-034)

Correct answer: D - When defined ranges can improve comparison despite limited precise loss data

Defined ranges provide more consistency than unstructured labels without claiming exact financial precision. The method cannot guarantee loss, convert technical severity directly to money, or omit business impact.

Question 8 (CISM7-035)**Correct answer: C - \$60,000**

Single loss expectancy is \$2,000,000 multiplied by 10%, or \$200,000. Multiplying by 0.3 gives an annualized loss expectancy of \$60,000.

Question 9 (CISM7-036)**Correct answer: B - Reevaluate likelihood using the new targeting evidence**

The new threat evidence directly affects likelihood, while unchanged consequences may leave impact stable. Stable controls do not reduce inherent risk, and waiting ignores relevant evidence.

Question 10 (CISM7-037)**Correct answer: C - An operating deficiency increasing unauthorized-access likelihood**

The control is designed appropriately but did not operate as required, making this an operating deficiency. Missed reviews are neither a realized impact nor proof that compromise occurred.

Question 11 (CISM7-038)**Correct answer: A - Report current residual risk and record the target state separately**

Residual risk must reflect controls operating now; the expected postimplementation level is target risk. A contract does not establish current effectiveness, alter inherent risk, or justify removing the scenario.

Question 12 (CISM7-039)**Correct answer: A - Biometric exposure because scale, irreversibility, and obligations increase consequence**

The biometric scenario carries broader, persistent, and obligation-related consequences hidden by equal scores. Asset labels and vulnerability counts do not replace business context.

Question 13 (CISM7-040)**Correct answer: B - A range or distribution with assumptions, confidence, and sensitivity**

Ranges, assumptions, confidence, and sensitivity show the result's decision value and limitations. A maximum is not an expected value, technical severity is not financial loss, and sparse data can still support transparent analysis.

Question 14 (CISM7-041)**Correct answer: A - Report aggregate concentration while preserving local entries**

The common dependency creates an enterprise scenario that local ratings obscure. Averaging or ignoring aggregation understates impact, while local entries remain useful for ownership.

Question 15 (CISM7-042)**Correct answer: B - Material scenarios, appetite, assumptions, and treatments**

Leaders need business consequences, exposure against appetite, assumptions, and response choices. Technical volume and effort do not establish materiality, while buying every control ignores proportionality.

Question 16 (CISM7-043)

Correct answer: A - Formally retaining residual exposure within authorized limits

Acceptance is the authorized decision to retain residual exposure. Discontinuing is avoidance, controls mitigate risk, and insurance shares specified financial consequences.

Question 17 (CISM7-044)

Correct answer: B - The risk owner accepts risk; control owners operate controls

Business risk owners decide within authority, while control owners operate controls. Security advises, audit remains independent, and outsourcing does not transfer organizational accountability.

Question 18 (CISM7-045)

Correct answer: A - The lower-impact control achieving acceptable risk

The lower-cost control meets the defined risk and obligation criteria with better business outcomes. Expense does not prove effectiveness, both are not justified, and acceptable risk need not be zero.

Question 19 (CISM7-046)

Correct answer: C - Comply or delay launch

A binding duty that cannot be waived requires compliant treatment or a changed launch decision. Ordinary acceptance, insurance, and later review do not remove the obligation.

Question 20 (CISM7-047)

Correct answer: A - Partial transfer retaining operational accountability

Insurance shares specified financial loss but leaves operational, reputational, excluded, and accountability exposure. It neither avoids the activity nor transfers all impact or responsibility.

Question 21 (CISM7-048)

Correct answer: A - Require risk-tiered data and subcontractor review

Early review preserves leverage to select, negotiate, treat, or obtain authorized acceptance. Later review is too late, blanket prohibition may be disproportionate, and procurement does not own all business risk.

Question 22 (CISM7-049)

Correct answer: B - Rate of high-confidence automated login attacks

The automated-attempt rate directly signals changing threat exposure. Courses, work hours, and policy reviews measure activity rather than the stated risk.

Question 23 (CISM7-050)

Correct answer: D - Reassess because exposure and a key control assumption changed

External access and weaker reconciliation invalidate material assumptions. The service name does not preserve the old exposure, and partners cannot accept the organization's risk.

Question 24 (CISM7-051)

Correct answer: A - Reassess before exception approval

The radio path undermines the compensating control, so coverage and residual exposure must be reassessed. Control presence is not proof, security should not accept for operations, and the path cannot be ignored.

Question 25 (CISM7-052)

Correct answer: D - Reassess exposure and controls

Repeated renewal, untested compensation, and changed authority require fresh assessment and approval. Automatic renewal, closure, or permanence would lack evidence and authority.

Question 26 (CISM7-053)

Correct answer: C - Invoke reassessment and a revised owner decision

The approved trigger is an early signal requiring reassessment. Raising it or waiting conceals the trend, and monitoring success does not close the underlying exposure.

Question 27 (CISM7-054)

Correct answer: D - Fund treatment and require acceptable residual-risk evidence at launch

Ownership, funding, and a gate criterion make treatment part of the release decision. A later backlog is too late, developers may lack authority, and changing the rating does not reduce exposure.

Question 28 (CISM7-055)

Correct answer: B - Report aggregate exposure while retaining local records

Local approvals can create unacceptable aggregate exposure requiring enterprise authority. Local records remain useful, while deletion or artificial division conceals rather than manages risk.

Question 29 (CISM7-056)

Correct answer: B - Use time-bound controls, documented acceptance, monitoring triggers, and a migration deadline

A conditioned, monitored, time-bound transition supports the business objective within approved tolerance. Indefinite acceptance exceeds scope, shutdown ignores the objective, and prior operation is not treatment evidence.

Question 30 (CISM7-057)

Correct answer: D - Material risk, treatment, exceptions, and decisions

Executive reporting should connect exposure to appetite, show treatment results and exceptions, and identify decisions. Raw tasks and spending lack outcome context, while delay prevents timely oversight.